Testaus

Sovelluksen toiminnalliset testit ovat tiedostossa `tests/app.test.js` ja tietoturvatestit tiedostossa `tests/security.test.js`. Testit suoritetaan Jestillä komennolla:

```
npm test
```

Mitä testataan ja miksi

Testit käyttävät `supertest`-kirjastoa Express-sovelluksen HTTP-reittien kutsumiseen. Tietokanta ja `bcrypt` on mockattu, jotta testit keskittyvät reittien toimintaan eivätkä riipu tietokannan nykyisestä sisällöstä tai salasanan hashauksen toteutuksesta.

Testi	Mitä testataan	Miksi tämä on tärkeää
Kirjautumissivun näyttäminen	`GET /auth/login` palauttaa HTTP 200 -vastauksen ja kirjautumissivun otsikon.	Varmistaa, että käyttäjä pääsee kirjautumisen aloitussivulle ja oikea näkymä renderöityy.
Kirjautumattoman käyttäjän ohjaaminen	`GET /` ohjaa kirjautumattoman käyttäjän osoitteeseen `/auth/login`.	Estää suojatun etusivun näyttämisen ilman voimassa olevaa istuntoa.
Onnistunut kirjautuminen	Oikeilla tunnuksilla `POST /auth/login` ohjaa etusivulle, asettaa `sessionId`-evästeen ja päivittää käyttäjän istunnon tietokantaan.	Varmistaa, että tunnistettu käyttäjä saa toimivan istunnon ja pääsee sovellukseen.
Virheelliset kirjautumistiedot	Väärällä salasanalla kirjautuminen näyttää virheilmoituksen eikä päivitä käyttäjän istuntoa.	Varmistaa, ettei epäonnistunut kirjautumisyritys anna käyttöoikeutta tai luo istuntoa.
Uuden käyttäjän rekisteröinti	`POST /auth/register` tallentaa käyttäjän hashatun salasanan ja ohjaa kirjautumissivulle.	Varmistaa uuden käyttäjätilin luomisen ja sen, ettei salasanaa tallenneta sellaisenaan.
Postauksen luominen tunnistettuna	Voimassa olevalla `sessionId`-evästeellä `POST /new-post` tallentaa postauksen ja ohjaa etusivulle.	Varmistaa, että kirjautunut käyttäjä voi luoda sisältöä ja että pyyntö käsitellään oikean käyttöoikeuden jälkeen.

Testien eristys

Jokaisen testin alussa mockien kutsuhistoria tyhjennetään. Tietokantamockit palauttavat oletuksena tilanteen, jossa kysely ei löydä tuloksia, ja yksittäiset testit muuttavat palautetta vain tarvitsemansa skenaarion ajaksi. Näin testit eivät riipu toistensa suoritusjärjestyksestä.

Rajaukset

Nykyiset testit varmistavat keskeiset onnistumis- ja kirjautumisvirhepolut, mutta eivät kata esimerkiksi seuraavia tilanteita:

- tyhjät tai virheellisesti muotoillut lomakekentät
- jo olemassa olevan käyttäjän rekisteröinti
- tietokantavirheet
- virheellinen tai vanhentunut istunto postauksen luonnissa
- postauksen muokkaus ja poistaminen
- näkymien yksityiskohtainen HTML-rakenne

Näitä varten tarvitaan erilliset testit, jos sovelluksen vaatimukset laajenevat.

Tietoturvatestit

Tietoturvatestit varmistavat, että salasanat tallennetaan hashattuina, istuntoeväste on `HttpOnly` ja satunnaisesti muodostettu, hallintasivu on rajattu ylläpitäjälle, kirjautumaton käyttäjä ei voi luoda postausta, kirjautumissyöte välitetään parametrina SQL-kyselyyn, postauksen sisältö escapetaan HTML:ssä ja uloskirjautuminen tyhjentää istuntoevästeen.

dokumentti on tehtyt tekoälyn avulla